

A Lightweight Authentication and Key Agreement Protocol for IoT-based Smart Healthcare System

Sangjukta Das

Department of Computer Science and
Engineering,

National Institute of Technology Patna,
Bihar, India
sangjukta24@gmail.com

Maheshwari Prasad Singh

Department of Computer Science and
Engineering,

National Institute of Technology Patna,
Bihar, India
mps@nitp.ac.in

Suyel Namasudra

Department of Computer Science and
Engineering,

National Institute of Technology
Agartala, Tripura, India
suyelnamasudra@gmail.com

Abstract—Nowadays, the enormous advantages of the Internet of Things (IoT) are being used in a variety of fields, including, but not limited to, transportation, healthcare, and traffic monitoring. However, the lack of strong security in IoT devices can put both the devices and the data at risk, which can be life-threatening in healthcare. Authentication of network devices is identified as a major security concern, particularly in the context of smart healthcare systems. This paper discusses a privacy-preserving authentication technique that provides session key agreement for smart healthcare systems. This scheme is developed by using simple cryptographic operations to cope with resource-constrained IoT devices. The proposed scheme aims to establish a secure session for authorized devices. Security analysis and performance analysis are conducted to evaluate the effectiveness of the proposed scheme, which is found to be more effective than existing schemes.

Keywords—Privacy-preserving, Untraceability, Session Key, Security.

I. INTRODUCTION

The Internet of Things (IoT) comprises a large collection of interconnected sensors or IoT devices that interact over the Internet. The IoT is playing a significant role in daily life by providing a wide range of Internet-based services in a variety of domains, including traffic monitoring [1], military, healthcare, and smart cities [2, 3]. These devices are placed in specific places to sense, gather data, or carry out specific tasks. Subsequently, once authorized, users are able to retrieve the necessary information from the appropriate data center [4]. Nonetheless, there are numerous other situations, where a user may need to directly access real-time sensor data. This is particularly true for scenarios, such as patient body sensors, military surveillance, and vehicular and individual tracking, where instantaneous access to data is essential. The combination of machine learning and IoT-based solutions with real-time access can assist professionals, organizations, and governments manage their resources effectively, deliver timely and accurate data, and minimize human participation [5, 6].

However, the wide use of IoT-based services has led to a rapid increase in security concerns. Therefore, it is crucial to develop strong security mechanisms to safeguard current IoT ecosystems from possible security threats [7, 8]. Authentication plays a vital role in providing security and protection against many security threats like man-in-the-middle (MITM), replay, traceability, user and device impersonation attacks, and many others. User authentication and key establishment method for IoT network was presented by Farash et al. [9]. This technique aims to provide secure and efficient communication between devices in IoT networks by addressing the challenges of user authentication

and key establishment. Amin et al. [10] found a number of flaws in this technique as well as a vulnerability to offline password guessing and user impersonation attacks. Sharma and Kalra [11] proposed another authentication scheme, which focuses on minimizing computational overhead and communication costs while maintaining the desired level of security. Another fresh technique for user-device authentication and key establishment was developed by Turkanovic et al. [12]. This technique was discovered to be susceptible to some attacks, including user impersonation, offline password guessing, and attacks on sensor nodes. A lightweight key management authentication technique appropriate for IoT applications was presented by Wazid et al. [13]. To provide quick and secure communication, this method employs bitwise XOR and a one-way cryptographic hash function. However, most of the above-discussed approaches are designed for user authentication. For device authentication, Chuang et al. [14] developed a secure continuous authentication scheme. This scheme provides continuous authentication by using the battery capacity value of a sensor device in an associated gateway. Lounis et al. [15] proposed another things-to-things authentication protocol based on Physically Unclonable Functions (PUF) for an IoT environment. This protocol uses PUF-generated keys to authenticate IoT devices. Li et al. [16] presented a mutual authentication and key agreement protocol with anonymity for a centralized two-tier IoT-based healthcare network. It ensures secure communication between wearable sensor devices. The main disadvantage of this scheme is that it faces key escrow issues. Gupta et al. [17] designed another lightweight user authentication and key establishment scheme for wearable devices. The primary objective of this scheme is to ensure secure communication between wearable devices while maintaining user anonymity. Gope et al. [18] proposed another lightweight authentication protocol to transfer real-time data in a wireless sensor network. This approach, however, asks for the gateway to save additional user data, which is impractical and often leads to failed authentication. This method does not support anonymity and untraceability. However, most of the device authentication and key agreement techniques are designed based on computationally expensive cryptographic operations [19-22]. To address these issues, a novel lightweight session key agreement technique is proposed in this article. The key contribution of this scheme is summarized below:

- A lightweight authentication and key agreement protocol is designed that can provide a secure session for data sharing among the IoT and gateway devices.
- To improve data security, this protocol uses a new session key during each new session, and a

timestamp mechanism is also used to keep the messages fresh in the authentication process.

- Additionally, the key update process at the end of each session enhances the anonymity of IoT devices.

The rest of the article is arranged as follows: Section II discusses the proposed authentication methodology. Section III presents a detailed security analysis. Section IV provides the results and analysis of the proposed scheme. Finally, Section V concludes the work and highlights future goals.

II. PROPOSED METHODOLOGY

In this work, an authentication technique that provides session key agreement for smart healthcare systems is developed. This scheme supports the processing power as well as solves privacy preservation issues of IoT devices. Gateway registers each IoT device according to the recommended method. During the registration phase, the necessary parameters and credentials for authentication will be shared, and the same shared credentials will be used for both authentication and session key agreement. During the authentication stage, the corresponding gateway verifies each registered device, at which point a secure session is established. The proposed scheme has two phases: the registration phase and the authentication and key agreement phase. The first phase, i.e., registration is a one-time process, and the authentication and key agreement phase is executed every time a secure session is required for data communication.

A. Registration Phase

During the registration process, a secure channel is utilized for communication between the device D_i and the gateway G_j , where $i = \{1, 2, \dots, I\}$, $j = \{1, 2, \dots, J\}$, and $I > J$. The steps of this procedure are sequentially discussed below:

Step 1: Each device D_i in the network contains a unique D_i 's identity D_{ID} . The D_i generates a fresh Registration Request (R_{Req}) and sends it to a gateway G_j .

TABLE I. DESCRIPTIONS OF NOTATIONS

Notation	Description
D_{ID}	Identity of the device
$\oplus, $	XOR and concatenation operator
n_1, g_1, g_2	Secret key values
AID	Anonymous identity of the device
R_{Device}	Registered device list
SK	Session key
T_c	Current timestamp

Step 2: On receiving $R_{Req}(D_{ID})$, G_j retrieves D_{ID} from R_{Req} . Then, it selects a random nonce x and a pre-shared key (PK_i) for D_i . G_j computes D_i 's anonymous identity $AID = D_{ID} \oplus x$ and $S_{Hash} = h(AID || PK_i)$. After this, the G_j stores D_i 's AID and PK_i in its registered device list (R_{Device}) and also sends these parameters to the D_i .

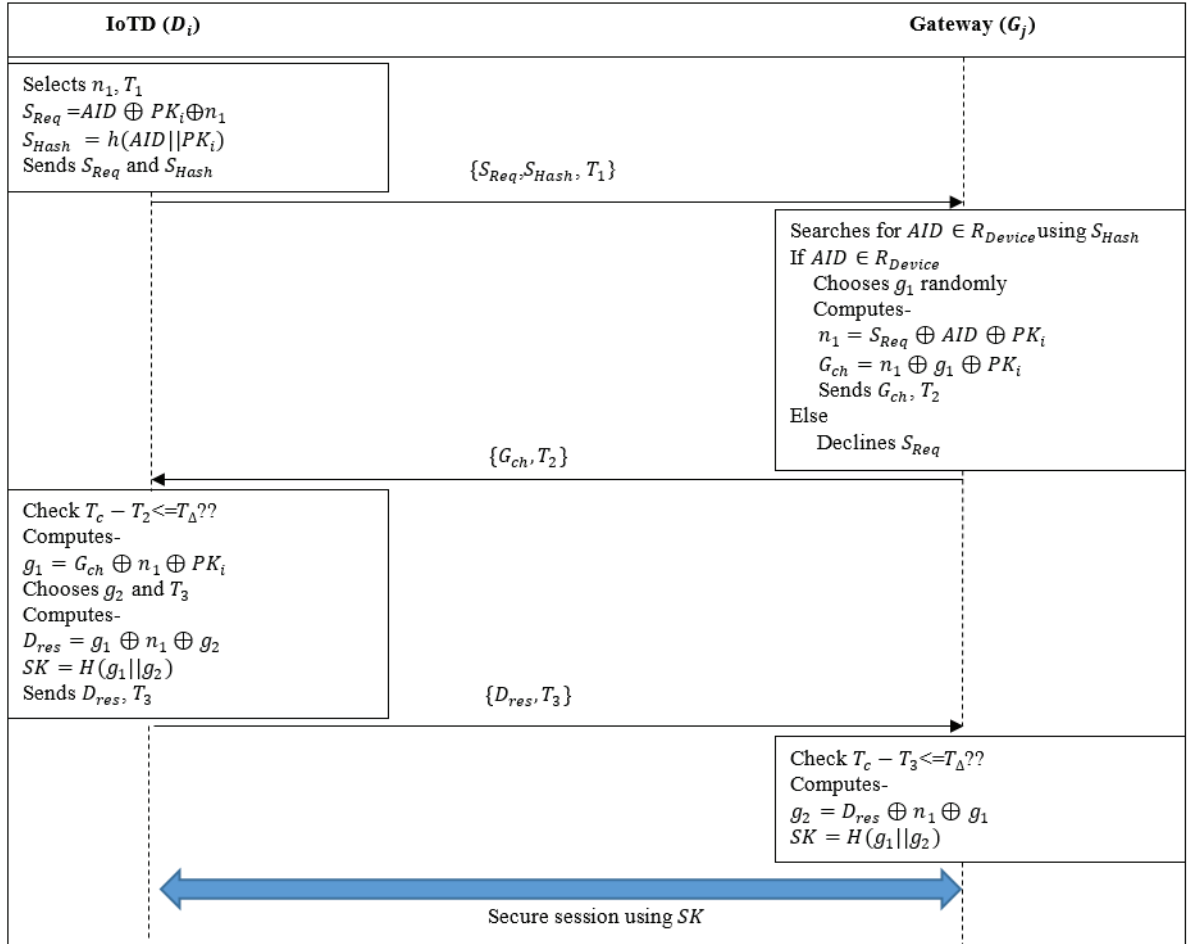


Fig. 1. Authentication and key agreement of the proposed scheme

Step 3: On receiving $\{AID, PK_i\}$, D_i stores them in its secure memory. Table I describes the notations used in this scheme

B. Authentication and Key Agreement Phase

The gateway can authenticate a registered device by utilizing the device's AID and PK_i . Then, both the gateway and IoT D can agree on a session key, and a secure session can be established for communication. This process is initiated by a device D_i . Fig. 1 outlines the entire key agreement procedure, which includes the below steps:

Step 1: Initially, the D_i generates a number n_1 randomly, and using n_1 , it calculates $S_{Req} = AID \oplus PK_i \oplus n_1$ and $S_{Hash} = h(AID || PK_i)$. Then, D_i sends the authentication request $\{S_{Req}, S_{Hash}, T_1\}$ at time T_1 to G_j .

Step 2: The G_j searches for AID using S_{Hash} in its R_{Device} list. If the AID is not recorded in this R_{Device} list, then, the S_{Req} is declined by the G_j . Otherwise, G_j continues the authentication process. The G_j retrieves n_1 from S_{Req} as it contains D_i 's AID , PK_i , and n_1 . Further, G_j chooses a random nonce g_1 and calculates a challenge $G_{ch} = n_1 \oplus g_1 \oplus PK_i$. Finally, the G_j sends the $\{G_{ch}, T_2\}$ to the D_i at time T_2 .

Step 3: On receiving $\{G_{ch}, T_2\}$, the D_i , at first, checks the validity of T_2 as $T_c - T_2 \leq T_\Delta$. Then, the D_i generates g_1 from G_{ch} by computing $g_1 = G_{ch} \oplus n_1 \oplus PK_i$ and calculates response $D_{res} = g_1 \oplus n_1 \oplus g_2$ after choosing a random nonce g_2 . The D_i sends $\{D_{res}, T_3\}$ to the G_j at time T_3 . The D_i also computes the session key $SK = H(g_1 || g_2)$.

Step 4: Once the parameters $\{D_{res}, T_3\}$ are received, the G_j checks T_3 's validity as $T_c - T_3 \leq T_\Delta$. Then, the G_j computes $g_2 = D_{res} \oplus n_1 \oplus g_1$ to generate the session key $SK = H(g_1 || g_2)$.

Thus, the authentication of IoT D with the concerned gateway completes. Both D_i and G_j can exchange data through a secure session using SK . Once data transmission completes, the session is terminated by discarding the current session key. At this stage, the anonymous identity and pre-shared key can be securely updated as AID_{new} and PK_{new} before terminating the ongoing session. The gateway can compute a new pre-shared key PK_{new} , $AID_{new} = H(AID \oplus x_{new})$, and S_{Hash} for D_i . Then, the G_j updates its R_{Device} list with new parameters and sends these parameters to the device through the secure channel. Finally, the device terminates the ongoing session by discarding SK .

III. SECURITY ANALYSIS

The proposed scheme's security analysis demonstrates its resilience and effectiveness. Initially, several potential threat scenarios are examined, and it is demonstrated that the proposed scheme is capable of withstanding these scenarios.

Theorem 1: A session can only be initiated by a registered device D_i with a concerned gateway G_j by sending a valid request S_{Req} .

Proof: During the device registration phase, each valid device D_i is assigned an anonymous identity AID and a pre-shared key PK_i by the corresponding gateway G_j . G_j maintains a record of device identity (D_{ID}), AID , PK_i , and S_{Hash} in its R_{Device} list for every registered device. Suppose

an intruder I_k tries to start a session by sending a S_{Req} to the G_j . G_j checks the sender's authenticity by checking S_{Hash} in its R_{Device} list. If S_{Hash} is not found, it implies that AID is not registered with G_j , i.e., $AID \notin \{AID_1, AID_2, \dots, AID_l\}$. In such a case, G_j rejects the S_{Req} and marks it as an intruder. Conversely, if a registered device D_i initiates a session by sending S_{Req} , the G_j verifies D_i 's authenticity by checking S_{Hash} in R_{Device} list. Therefore, a registered device D_i can only establish secure sessions with the gateway G_j . This completes the proof.

Theorem 2: The proposed protocol can prevent the MITM attack.

Proof: Consider that an adversary tries a MITM attack against the IoT D and gateway. The adversary must calculate valid messages in accordance with the proposed authentication process. Any attacker, however, will be unable to extract a valid message without the proper pre-shared key and secret values. It is also computationally impossible for an adversary to modify the original messages without discovering the secret key values. As a result, the proposed protocol can prevent the MITM attack.

Theorem 3: The proposed protocol can prevent the replay attack.

Proof: when a potential attacker tries a replay attack by intercepting messages that are used for authentication between a device and gateway. To guarantee network transmission delay for all delivered messages, the proposed protocol uses a timestamp. Even if the attacker selects a fresh timestamp, the hash function prevents the attacker from changing the original timestamp incorporated in the authentication messages. Consequently, this scheme is protected from replay attacks.

A. Security Comparison

Comparing the proposed scheme's security features against those of other existing schemes [16 and 17]. A few security attacks, including MITM and eavesdropping attacks, are taken into consideration in this comparison and are displayed in Table II.

TABLE II. SECURITY FEATURE COMPARISON

Features	Li et al. [16]	Gupta et al. [17]	Proposed Scheme
Forward secrecy	Y	Y	Y
MITM	Y	Y	Y
Eavesdropping	Y	Y	Y
DoS	N	N	Y
Replay	Y	Y	Y
Anonymity	N	Y	Y

IV. RESULT AND ANALYSIS

A. Verification using AVISPA Tool

AVISPA is a tool used for the verification and validation of security protocols and applications. AVISPA supports the analysis of several security properties, such as secrecy, authentication, and integrity. It can analyze a wide range of protocols, including key exchange, authentication, and cryptographic protocols by using different techniques, such as model checking and automated theorem proving. It provides a user-friendly interface and can generate detailed reports of the analysis results. Any security model can be

% OFMC % Version of 2006/02/13 SUMMARY SAFE DETAILS BOUNDED_NUMBER_OF_SESSIONS PROTOCOL /home/span/span/testsuite/results/authentication.if GOAL as_specified BACKEND OFMC COMMENTS STATISTICS parseTime: 0.00s searchTime: 0.02s visitedNodes: 38 nodes depth: 4 plies	SUMMARY SAFE DETAILS BOUNDED_NUMBER_OF_SESSIONS TYPED_MODEL PROTOCOL /home/span/span/testsuite/results/authentication.if GOAL As Specified BACKEND CL-AtSe STATISTICS Analysed : 0 states Reachable : 0 states Translation: 0.00 seconds Computation: 0.00 seconds
--	---

Fig. 2. Output summary of AVISPA simulation tool.

TABLE III. COMPUTATION COST COMPARISON

Scheme	D_i	G_j	Total
Li et al. [16]	$3H_T + 7X_T$	$4H_T + 12X_T$	$7H_T + 19X_T$
Gupta et al. [17]	$4H_T + 4X_T$	$5H_T + 3X_T$	$9H_T + 7X_T$
Proposed scheme	$1H_T + 3X_T$	$1H_T + 3X_T$	$2H_T + 6X_T$

TABLE IV. COMPUTATION COST COMPARISON

Scheme	Total no. of messages	Total no. of bits
Li et al. [16]	4	4672
Gupta et al. [17]	5	3808
Proposed scheme	3	544

specified using this tool's HLPSSL codes. An HLPSSL2IF translator first converts the HLPSSL code into an IF (Intermediary From). The IF is sent to AVISPA tool's backends for further processing.

By using SPAN animator of the AVISPA simulation tool in 32-bit Ubuntu OS, the proposed protocol's HLPSSL specification is analyzed. The SUMMARY shown in Fig 2 demonstrates that the proposed scheme is SAFE and can effectively withstand various attacks, including impersonation, replay, and MITM attacks. Moreover, it demonstrates the preservation of confidentiality of the session key. Therefore, this scheme is useful for the practical use.

B. Computation Cost

In this subsection, a comparison of the computation cost between the proposed scheme and the existing schemes [16 and 17] is conducted, under the same conditions and operations. The fundamental operations employed in both the proposed scheme and the existing schemes include hash, XOR, and concatenation ($\parallel$). However, to evaluate cost the hash operations are solely considered as they are relatively more time-consuming compared to the other operations. A hash (SHA-256) operation takes 0.0008 ms [23]. The number of operations employed in both the proposed and existing schemes is compared, which is listed in Table III.

C. Communication Cost

Table IV compares the communication cost of the proposed scheme and existing schemes by highlighting the number of messages transmitted and received, as well as the corresponding number of bits exchanged by the communicating entities. The proposed scheme exchanges significantly fewer bits and messages in comparison to the other schemes.

V. CONCLUSION

In this paper, a lightweight session key agreement protocol through authentication for smart healthcare is proposed that aims to establish a secure session for authorized devices while coping with resource-constrained IoT devices. The security and performance analysis show that the proposed scheme is more effective than existing schemes, providing better security and efficiency. The proposed authentication technique can be implemented in various smart healthcare systems, ensuring the confidentiality and integrity of patient data and improving the overall quality of patient care. Future work can focus on the practical implementation of the proposed scheme and further improvements in security and efficiency.

REFERENCES

- [1] Q. Mei, H. Xiong, Y. -C. Chen and C. -M. Chen, "Blockchain-enabled privacy-preserving authentication mechanism for transportation CPS with cloud-edge computing", *IEEE Transactions*

- [2] A. K. Sikder, A. Acar, H. Aksu, A. S. Uluagac, K. Akkaya, and M. Conti, "IoT-enabled smart lighting systems for smart cities", In *Proceedings of IEEE Annual Computing and Communication Workshop and Conference (CCWC)*, Las Vegas, NV, USA, 2018, pp. 639-645.
- [3] S. Das and S. Namasudra, "Multi-authority CP-ABE-based access control model for IoT-enabled healthcare infrastructure", *IEEE Transactions on Industrial Informatics*, vol. 19, no. 1, pp. 821-829, 2023.
- [4] S. Namasudra and P. Roy, "Size based access control model in cloud computing", In *Proc. of the International Conference on Electrical, Electronics, Signals, Communication and Optimization*, IEEE, Visakhapatnam, India, 2015, pp. 1-4.
- [5] Y. K. Huang, "Design of a smart cabin lighting system based on internet of things", *Cloud Computing and Data Science*, vol. 4, no. 2, pp. 112-121, 2023.
- [6] A. Kishor, C. Chakraborty, and W. Jeberson, "A novel fog computing approach for minimization of latency in healthcare using machine learning", *International Journal of Interactive Multimedia and Artificial Intelligence*, vol. 6, pp. 7-17, 2020.
- [7] H. Jennath, V. S. Anoop, and S. Asharaf, "Blockchain for healthcare: securing patient data and enabling trusted artificial intelligence", *International Journal of Interactive Multimedia and Artificial Intelligence*, vol. 6, pp. 15-23, 2020.
- [8] S. Das and S. Namasudra, "A novel hybrid encryption method to secure healthcare data in IoT-enabled healthcare infrastructure", *Computers and Electrical Engineering*, vol. 101, pp. 1-15, 2022.
- [9] M. S. Farash, M. Turkanović, S. Kumari, and M. Hölbl, "An efficient user authentication and key agreement scheme for heterogeneous wireless sensor network tailored for the Internet of Things environment", *Ad Hoc Networks*, vol. 36, pp. 152-176, 2016.
- [10] R. Amin, S. H. Islam, G. P. Biswas, M. K. Khan, L. Leng, and N. Kumar, "Design of an anonymity-preserving three-factor authenticated key exchange protocol for wireless sensor networks", *Computer Networks*, vol. 101, pp. 42-62, 2016.
- [11] G. Sharma and S. Kalra, "A lightweight user authentication scheme for cloud-IoT based healthcare services", *Iranian Journal of Science and Technology, Transactions of Electrical Engineering*, vol. 43, no. 1, pp. 619-636, 2019.
- [12] M. Turkanovic, B. Brumen, and M. Hölbl, "A novel user authentication and key agreement scheme for heterogeneous ad hoc wireless sensor networks, based on the Internet of Things notion", *Ad Hoc Networks*, vol. 20, pp. 96-112, 2014.
- [13] M. Wazid, A. K. Das, S. Shetty, J. J. P. C. Rodrigues, and Y. Park, "LDAKM-ElIoT: Lightweight device authentication and key management mechanism for edge-based IoT deployment", *Sensors*, vol. 19, no. 24, pp. 1-21, 2019.
- [14] Y. H. Chuang, N. W. Lo, C. Y. Yang, and S. W. Tang, "A lightweight continuous authentication protocol for the Internet of Things", *Sensors*, vol. 18, no. 4, pp. 1-26, 2018.
- [15] K. Lounis and M. Zulkernine, "T2t-map: A puf-based thing-to-thing mutual authentication protocol for IoT", *IEEE Access*, vol. 9, pp. 137384-137405, 2021.
- [16] X. Li, M. H. Ibrahim, S. Kumari, A. K. Sangaiah, V. Gupta, and K. K. R. Choo, "Anonymous mutual authentication and key agreement scheme for wearable sensors in wireless body area networks", *Computer Networks*, vol. 129, pp. 429-443, 2017.
- [17] A. Gupta, M. Tripathi, T. J. Shaikh, and A. Sharma, "A lightweight anonymous user authentication and key establishment scheme for wearable devices", *Computer Networks*, vol. 149, pp. 29-42, 2019.
- [18] P. Gope and T. Hwang, "A realistic lightweight anonymous authentication protocol for securing real-time application data access in wireless sensor networks", *IEEE Transactions on Industrial Electronics*, vol. 63, no. 11, pp. 7124-7132, 2016.
- [19] S. Das and S. Namasudra, "Lightweight and efficient privacy-preserving mutual authentication scheme to secure Internet of Things-based smart healthcare", *Transactions on Emerging Telecommunication Technology*, 2023. DOI: 10.1002/ett.4716.
- [20] J. Chen, H. Xiao, M. Hu, C. M. Chen, "A blockchain-based signature exchange protocol for metaverse", *Future Generation Computer Systems*, vol. 142, pp. 237-247, 2023.
- [21] S. Das and S. Namasudra, "MACPABE: Multi-authority-based CP-ABE with efficient attribute revocation for IoT-enabled healthcare infrastructure", *International Journal of Network Management*, 2022. DOI:10.1002/nem.2200.
- [22] S. Khasim and S. S. Basha, "An improved fast and secure CAMEL based authenticated key in smart health care system", *Cloud Computing and Data Science*, vol. 3, no. 2, pp. 77-91, 2022.
- [23] L. Xu and F. Wu, "Cryptanalysis and improvement of a user authentication scheme preserving uniqueness and anonymity for connected health care", *Journal of Medical Systems*, vol. 39, no. 2, pp. 1-9, 2015.